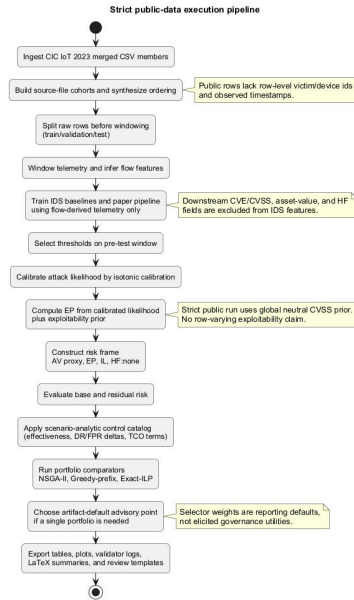


Graphical Abstract

A Machine-Readable Standards-Traceability Framework for Cybersecurity Risk Evidence in IoT Environments

Ercan Erkalkan



Highlights

A Machine-Readable Standards-Traceability Framework for Cybersecurity Risk Evidence in IoT Environments

Ercan Erkalkan

- UML/XMI artifact captures standards-traceable cybersecurity risk evidence.
- GQM mappings structurally cover 93 ISO and 106 NIST CSF 2.0 entries.
- Executable validators check coverage, links, duplicates, and schema integrity.
- Reporting exports preserve traceability from evidence to standards artifacts.
- Portfolio layer exposes residual-risk and three-year TCO trade-offs.

A Machine-Readable Standards-Traceability Framework for Cybersecurity Risk Evidence in IoT Environments

Ercan Erkalkan^{a,*}

^aMarmara University, Vocational School of Technical Sciences, Department of Computer Technologies, Mehmet Genc Kulliyesi, Istanbul, 34865, Turkey

Abstract

This study presents a machine-readable, standards-traceable framework for representing cybersecurity risk evidence. The proposed artifact encodes heterogeneous evidence into a UML/XMI knowledge model and structurally covers 93/93 ISO/IEC 27001:2022 Annex A controls and 106/106 NIST CSF 2.0 subcategories through an executable Goal–Question–Metric mapping. To demonstrate operationalization under strict public-data constraints, the framework is instantiated on a telemetry-only CIC IoT 2023 profile. This public experiment demonstrates representation-level traceability, executable validation, telemetry-derived evidence generation, and reporting/export reproducibility. It does not constitute a full empirical validation of the complete AV–EP–IL–HF risk formulation because the reported public profile uses a global neutral CVSS prior, telemetry-proxy asset values, no observed human-factor overlay, source-file cohort attribution, and synthesized ordering. The contribution therefore lies in the standards-traceable representation, structural validation, and reproducible reporting artifact rather than in deployment-level validation of all downstream risk factors.

Keywords: Cybersecurity risk representation, Standards traceability, ISO/IEC 27001, NIST CSF 2.0, UML/XMI, Goal–Question–Metric, Interoperability

*Corresponding author.

Email address: `ercan.erkalkan@marmara.edu.tr` (Ercan Erkalkan)

1. Introduction

Cybersecurity risk management increasingly depends on heterogeneous evidence sources, including operational telemetry, vulnerability feeds, control metrics, audit records, and human-factor indicators. In practice, these evidence streams are generated by different tools, expressed at different levels of abstraction, and maintained in formats that are difficult to reconcile across governance, engineering, and audit workflows. Although widely used frameworks such as ISO/IEC 27001:2022, ISO/IEC 27005, and NIST CSF 2.0 provide structured guidance for risk-based decision making, they do not by themselves provide a machine-readable representation that links operational evidence to controls, risk constructs, and standards coverage in a reusable and verifiable form.

This gap becomes more pronounced in IoT-oriented environments, where asset heterogeneity, high event volume, and rapidly changing exposure conditions complicate the interpretation of security evidence. Intrusion detection systems, anomaly detectors, vulnerability intelligence, and awareness-related indicators can each provide useful signals, yet these signals are often consumed in isolation. As a result, organizations may achieve strong local analytics while still lacking a common representation that supports traceability, comparability, validation, and standards-aligned reporting. The problem is therefore not only one of detection quality, but also one of evidence integration, semantic consistency, and governance usability.

Existing risk registers and qualitative scoring schemes are often insufficient for this setting because they aggregate heterogeneous observations into coarse categories without preserving provenance, calibration, or explicit mappings to standards artifacts. At the same time, machine-learning outputs are frequently reported as standalone performance results rather than as components of a standards-traceable decision workflow. This creates a persistent disconnect between analytics, control selection, and audit-facing governance. A central need therefore remains for a structured artifact that can represent cybersecurity risk evidence in machine-readable form, validate its mappings to standards, and support downstream risk and portfolio analyses without losing traceability across the full evidence chain.

1.1. Motivation and Problem Statement

The main difficulty in contemporary cybersecurity risk management is not only the availability of security signals, but the lack of a common, machine-

readable structure for representing them in a standards-aligned manner. In IoT-oriented environments, telemetry summaries, vulnerability descriptors, audit observations, control metrics, and human-factor indicators are typically produced by separate tools and maintained with different semantics. Although ISO/IEC 27001:2022, ISO/IEC 27005, and the NIST RMF encourage traceable and repeatable risk assessment, they do not by themselves define an interoperable representation layer that can transform heterogeneous operational evidence into reusable risk artifacts with explicit links to controls, governance objectives, and standards coverage.

This limitation affects not only technical analysis but also validation and governance. Risk registers and qualitative scoring schemes often compress heterogeneous observations into coarse categories, which weakens provenance, comparability, and calibration across assets and time. At the same time, AI-enabled security analytics can generate anomaly scores, class probabilities, and related evidence streams, yet these outputs are frequently consumed as isolated analytical products rather than as elements of a standards-traceable evidence chain. Without a unifying representation and validation mechanism, such signals remain difficult to reconcile with formal control mappings, difficult to reuse across audit and reporting workflows, and difficult to explain consistently in governance settings.

Three practical gaps follow from this situation. First, operational evidence, vulnerability context, and socio-technical indicators are rarely represented within a single auditable structure that preserves semantics and provenance. Second, mappings from evidence items to ISO/IEC 27001 and NIST CSF objectives are often incomplete or non-machine-readable, which limits validation, interoperability, and reporting reuse. Third, downstream quantitative risk and portfolio analyses are commonly performed without an explicit representation layer that maintains end-to-end traceability from raw evidence to control recommendations. The method proposed in response to these gaps is referred to throughout the manuscript as the proposed standards-traceable risk framework.

1.2. Research Questions

To address the identified representation, validation, and governance gaps, the study is structured around four research questions:

RQ1 Representation: How can heterogeneous cybersecurity evidence—including assets, threats, vulnerabilities, events, controls, and metric

classes—be encoded in a reusable, machine-readable, and standards-aligned knowledge model?

RQ2 Validation and standards traceability: How can mappings from evidence items to ISO/IEC 27001:2022 and NIST CSF 2.0 artifacts be represented and validated so that coverage, integrity, and traceability can be demonstrated in a reproducible manner?

RQ3 Telemetry-evidence transformation: How can telemetry-derived security evidence be transformed into traceable risk-facing quantities and budget-aware scenario comparisons while preserving provenance and making inactive or proxy risk factors explicit?

RQ4 Governance-facing export provisioning: How can decision rationales, validation outputs, and standards-linked metrics be exported in traceable reporting-facing forms that could support downstream audit, dashboard, reporting, or continuous-improvement workflows?

For RQ2, evaluation focuses on standards-coverage and validation evidence, including mapping completeness, broken-link checks, duplicate-row checks, dangling-row checks, machine-readable consistency across UML/XMI and GQM artifacts, and bidirectional ISO–NIST informative-reference consistency. These checks establish representation-level integrity and cross-framework consistency; they do not by themselves prove that every evidence-to-control mapping is the only possible interpretation. For RQ3, evaluation focuses on telemetry-only evidence-generation quality and downstream scenario-analysis behaviour, including residual risk, three-year TCO, detection rate (DR), false-positive rate (FPR), F_1 score, area under the receiver-operating characteristic curve (AUROC), precision–recall AUC (PR-AUC), and the Brier score. Operating thresholds are selected on the pre-test window and then evaluated on the hold-out test split. For RQ4, evaluation focuses on whether the generated tables, plots, validator outputs, and schema-linked exports preserve links from controls and subcategories to metrics, residual-risk summaries, and portfolio quantities in reporting-facing form. This checks export-layer traceability and packaging; it does not by itself establish auditor uptake, end-user usability, or deployed tool integration.

1.3. Scope and Contributions

The empirical scope of the study is intentionally framed as a public-data operationalization and representation-level evaluation of the proposed arti-

fact rather than as a full deployment validation of the complete risk engine. The framework is instantiated on IoT-heavy network telemetry with offline vulnerability enrichment using the public CIC IoT 2023 corpus, which provides multi-scenario flow records for benign and malicious traffic in heterogeneous IoT deployments [1, 2]. In the reported artifact run, all 63 merged CSV members are consumed under a resource-aware row budget. The headline evaluation is telemetry-only and boundary-safe: intrusion-detection models use only flow-derived telemetry, while CVE/CVSS, human-factor, and asset-value terms are introduced only after classification in the downstream representation and risk layers. The public release also provides an attack-victim inventory, which is retained as provenance metadata, but the released CSV files do not expose row-level victim identifiers and therefore cannot be deterministically joined back to individual flows. Accordingly, the strict public-data profile treats the 63 merged members as source-file cohorts, derives telemetry-proxy asset values, disables event-only CVE surrogates, and falls back to a global neutral CVSS prior unless a curated asset- or timestamp-level manifest is supplied. The strict public evaluation should therefore be interpreted as a representation-level and telemetry-evidence demonstration. It checks structural coverage, traceability, executable consistency, and reproducible exports, but it does not empirically validate row-varying CVSS exploitability, verified enterprise asset values, observed human-factor effects, or measured control intervention effects. External validity beyond IoT-oriented environments is discussed qualitatively rather than claimed empirically.

Within this scope, the study makes four main contributions:

- C1. Machine-readable standards-traceability artifact:** A reusable UML/XMI-based representation for cybersecurity risk evidence that encodes assets, threats, vulnerabilities, events, controls, and metric classes in a standards-aligned knowledge model linked to ISO/IEC 27005 and NIST RMF concepts.
- C2. Validation and mapping layer:** We provide an executable structural validation layer that checks standards coverage, identifier consistency, evidence-to-metric linkage, and report-generation completeness. A machine-readable Goal–Question–Metric mapping and validation workflow provides structural coverage for **all ISO/IEC 27001:2022 Annex A controls (93)** and **all NIST CSF 2.0 subcategories (106)**. This contribution concerns reproducible standards traceability and structural consistency rather than a compliance oracle.

- C3. Telemetry-evidence-to-risk demonstration with explicit activation boundaries:** An auditable transformation architecture is provided for hosting AV, EP, IL, and optional HF terms within a standards-linked risk representation. In the strict public-data profile, only the telemetry-derived likelihood path is empirically activated. CVSS exploitability is represented by a constant global neutral prior, asset value is represented by a telemetry-derived source-cohort proxy, and the human-factor term is inactive because no observed HF overlay is available. Therefore, this contribution should be interpreted as a representation-level and telemetry-evidence demonstration, not as a full public-data validation of all AV–EP–IL–HF factors.
- C4. Budget-constrained portfolio comparison as a scenario-analytic operational demonstration:** A downstream advisory layer that compares control portfolios under a portfolio-level Gordon–Loeb bound using configurable control-catalog assumptions. On the reported strict public-data profile, NSGA-II returns a 61-point trade-off set (HV=31,436.9), Greedy returns a 14-point prefix frontier (HV=30,810.2), and Exact-ILP returns a 16-point log-space frontier (HV=28,970.3) on the (ResidualRisk, $\text{TCO}_{3y}^{\text{ctrl}}$) plane. Any single recommended point is treated as an artifact-default advisory selection rather than as a governance-optimal prescription; under the default selector, the chosen NSGA-II point yields 4.5% lower mean residual risk and 5.0% higher three-year control TCO relative to the matched-budget Greedy comparator.

1.4. Background and Related Work

The most relevant literature for the present study spans four intersecting streams: standards-oriented risk frameworks, quantitative risk transformation methods, AI-generated security evidence, and traceability-oriented metric and portfolio workflows. Rather than treating these streams as isolated topics, the present review emphasizes how they relate to a central Computer Standards & Interfaces concern: whether heterogeneous cybersecurity evidence can be represented, validated, and reused in a machine-readable, standards-aligned form. The discussion therefore focuses not only on analytical capability, but also on representation structure, validation logic, interoperability potential, and governance-facing reuse.

1.4.1. Standards-Oriented Risk Frameworks and Representation Gaps

Enterprise risk management standards such as ISO 31000 and its predecessor AS/NZS 4360 define generic processes for establishing context, identifying risks, analyzing likelihood and impact, and selecting treatments across organizational domains [3, 4]. ISO/IEC 27005 specializes these concepts for information security by introducing asset inventories, threat and vulnerability catalogs, likelihood–impact structures, and iterative treatment cycles coupled to ISO/IEC 27001 controls [5]. NIST SP 800-30 and related guidance similarly emphasize cyclical assessment, response, and monitoring, with explicit links to control baselines [6]. Frameworks such as OCTAVE FORTE operationalize self-directed profiling and workshop-driven analysis aligned with risk management tasks [7].

Gap: Standards-oriented frameworks define processes, concepts, and control contexts, but they stop short of providing a reusable machine-readable representation layer that can encode heterogeneous operational evidence, validate mappings, and support interoperable downstream reuse across audit, governance, and analytical workflows.

1.4.2. Quantitative Risk Transformation and Machine-Readable Gaps

Quantitative risk analysis methods extend qualitative schemes by expressing risk as a function of probability and impact. Classical approaches, including Annualized Loss Expectancy, decision-theoretic formulations, and analytic hierarchy process (AHP)-based weighting, assign monetary valuations to assets and estimate loss frequencies to support investment decisions [8]. The Gordon–Loeb model demonstrates that optimal security expenditure rarely exceeds approximately 37 % of the expected loss for a given information asset, providing a widely cited economic bound on security investment [9]. Later work introduces Bayesian and Monte Carlo formulations that propagate uncertainty in frequency and magnitude parameters and define scenario-based loss distributions for cyber risk [10].

The Factor Analysis of Information Risk (FAIR) methodology structures loss events into explicit frequency and magnitude factors, supported by a taxonomy and process guidance for calibrating parameters in currency terms [11]. In practice, FAIR-style models are often combined with high-level frameworks such as ISO/IEC 27001 or the NIST Cybersecurity Framework to improve risk quantification, but typically with organization-specific adaptations and without a standard machine-readable representation [12, 13].

Gap: Quantitative and FAIR-like approaches provide economic structure

and risk-factor decomposition, but they rarely specify how heterogeneous evidence should be represented in machine-readable form before numerical transformation, how such transformations remain traceable to standards artifacts, or how validation and interoperability should be preserved across the representation-to-risk pipeline.

1.4.3. AI-Generated Security Evidence and Analytical Transformation

Machine learning and, more recently, deep learning have significantly advanced intrusion detection and anomaly detection. Early expert-system and hybrid anomaly-misuse detectors demonstrated that combining statistical models with signature-based rules yields improved coverage compared with purely rule-based systems [14]. Subsequent surveys synthesize supervised, unsupervised, and hybrid intrusion-detection approaches, emphasizing the importance of feature engineering, traffic representation, and dataset realism [15]. Recent work reports that machine-learning-based intrusion detection can improve detection performance but also highlights the need for explainability, controllability, and robust evaluation against adversarial behavior [16].

For time-series and industrial contexts, interpretable and calibrated anomaly detectors have received particular attention. Extensive evaluations of unsupervised time-series anomaly detection methods underline the importance of calibrated probability outputs and reliability analysis [17]. Interpretable deep-learning architectures for industrial control and SCADA environments attach explanation mechanisms or structured feature attributions to sequence models in order to meet audit and safety requirements [18]. Lightweight designs for intrusion detection tailored to Internet of Things deployments illustrate how resource constraints and deployment topologies affect model architecture and performance trade-offs [19]. Incremental and online learning approaches further address non-stationary traffic patterns and concept drift in streaming settings [20].

Gap: AI-enhanced intrusion-detection research primarily improves analytical performance, calibration, and interpretability, yet the resulting signals are still often treated as endpoint outputs rather than as machine-readable evidence objects that can be validated, linked to standards artifacts, and reused consistently in downstream risk and governance workflows.

1.4.4. Traceability, GQM, and Budget-Constrained Downstream Decision Support

Cost-benefit analysis and optimization for security controls build on economic risk models and metrics-based governance. The Gordon–Loeb framework provides a theoretical upper bound on rational security investment relative to expected loss [9]. Multi-objective optimization techniques, such as the Non-Dominated Sorting Genetic Algorithm II (NSGA-II), have been applied to security-hardening and configuration problems to balance conflicting objectives like risk reduction, financial cost, and usability [21]. These formulations often encode control-selection decisions as binary vectors and evaluate fitness based on simulated attack graphs or scenario analyses, producing Pareto fronts rather than single-point recommendations.

The Goal–Question–Metric (GQM) paradigm provides a complementary perspective by deriving measurable indicators from high-level goals through intermediate questions [22]. Security-focused adaptations of GQM define key performance indicators for policy compliance, incident response, and awareness programs and encourage alignment between organizational objectives and technical metrics. However, many applications remain at the level of conceptual scorecards or dashboards and do not embed metrics into a formal data model or an explicit optimization loop that selects control portfolios.

Gap: Existing GQM and cost-effectiveness studies provide valuable metric hierarchies and portfolio heuristics, but they seldom define a full standards-traceable workflow in which evidence items, mappings, validation checks, and downstream portfolio comparisons remain connected through a common machine-readable artifact.

1.4.5. Summary of Gaps and Positioning

Across these four streams, a common limitation persists: cybersecurity risk workflows are often rich in concepts, metrics, or analytics, but comparatively weak in machine-readable representation, validation logic, and interoperable reuse. Standards-oriented frameworks define governance structure without fully specifying reusable evidence artifacts; quantitative approaches transform risk factors without fully preserving representation-level traceability; AI-based studies generate strong analytical signals without consistently turning them into standards-linked evidence objects; and GQM or portfolio studies support metrics and decisions without maintaining an explicit end-to-end representation chain.

The present study is positioned at this intersection. The central contri-

bution is not merely a quantitative risk score or an optimization routine, but a machine-readable standards-traceability framework that connects heterogeneous cybersecurity evidence to controls, governance objectives, and downstream decision processes. In this positioning, the UML/XMI knowledge model provides the representation layer, the GQM matrix and validator provide the validation layer, the $AV \times EP \times IL$ formulation provides the traceable transformation layer, and the Gordon–Loeb-bounded portfolio analysis serves as a downstream operational demonstration rather than as the sole core contribution. This combination distinguishes the framework from prior studies that address only one or two of these layers in isolation.

The remainder of the manuscript details the architecture and methodology (Section 2), presents empirical results (Section 3), discusses implications, limitations, and future work (Section 4), and closes with concluding remarks (Section 5).

2. Methods

This section describes the proposed framework as a standards-traceable representation, validation, and downstream operationalization architecture. The presentation is organized around four cooperating layers: a machine-readable knowledge model, a standards-mapping and validation layer, a traceable quantitative risk-transformation layer, and a downstream advisory layer used for portfolio comparison under explicit budget constraints. Figure 1 summarizes this organization, while detailed algorithmic settings and extended experimental protocols are provided in the Appendices and in the public repository (GitHub repository).

Four-layer standards-traceable architecture and public-run boundary

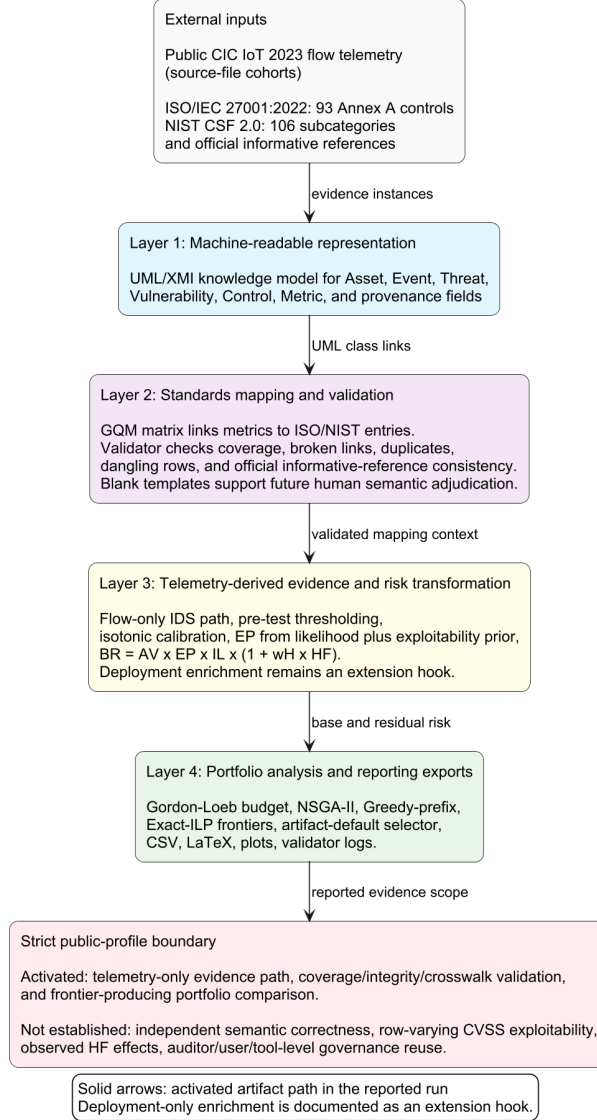


Figure 1: Four-layer standards-traceable architecture and strict public-profile evidence boundary. The figure distinguishes the activated artifact path from deployment-only enrichment hooks and unestablished validation claims.

2.1. Overall Architecture

The proposed framework is organized as a four-layer standards-traceable architecture that addresses the representation, validation, transformation, and downstream-use questions posed in RQ1–RQ4 (Fig. 1). The framework is intentionally structured so that analytical modules remain subordinate to the representation and traceability logic rather than defining the full contribution by themselves.

- 1) **Machine-Readable Knowledge Representation Layer** (blue) encodes ISO/IEC 27005 and NIST RMF entities such as *Asset*, *Threat*, *Vulnerability*, *Event*, *Risk*, and *RiskTreatment*, together with associated metric classes. This layer provides the common representation artifact through which heterogeneous cybersecurity evidence can be expressed in a reusable and standards-aligned form.
- 2) **Standards-Mapping and Validation Layer** (purple) links evidence items and metric classes to ISO/IEC 27001:2022 Annex A controls and NIST CSF 2.0 subcategories through a machine-readable Goal–Question–Metric structure. This layer supports coverage validation, integrity checks, and traceability demonstration across standards artifacts and implementation objects.
- 3) **Traceable Quantitative Risk-Transformation Layer** (orange) converts represented evidence into auditable quantitative risk constructs using Asset Value (AV), Event Probability (EP), Impact Level (IL), and optional Human-Factor (HF) terms, together with residual-risk and cost formulations. This layer serves as the transformation bridge between represented evidence and governance-relevant decision variables.
- 4) **Downstream Portfolio-Advisory Layer** (green) consumes the transformed risk quantities and compares feasible control portfolios under a Gordon–Loeb-type spending bound. In this architecture, portfolio optimization is treated as a downstream operational use of the represented and validated evidence chain rather than as the sole defining contribution of the framework.

Connectors in Fig. 1 denote the activated artifact path and the retained traceability links across these layers. This organization ensures that detections, mappings, risk transformations, and portfolio outputs can be recon-

structured from shared evidence objects and standards-linked artifacts during audit, governance, and reporting workflows.

2.2. Standards-Aligned Data Model (UML)

The UML-based data model serves as the machine-readable representation core of the framework and consists of a *conceptual layer* and a *metric layer*, as illustrated in Figs. 2 and 3.

- **Asset**, **Threat**, **Vulnerability**, **Event**, **Impact**, and **Risk**;
- **RiskTreatment**, **SecurityRequirement**, and **SecurityObjective**, together with provenance attributes and relationships.

Cardinalities follow IEEE 1016-2017 conventions; for example, a **Threat** may target one or more **Vulnerability** instances, while a **RiskTreatment** may mitigate several **Risk** instances. These associations align the model with ISO/IEC 27005 Tasks 2–5 (context, assessment, treatment, and monitoring) and NIST RMF steps.

The metric layer introduces five core metric classes and one human-factor class:

- **AssetValue**, **EventPotential**, and **ImpactLevel** hold the quantitative factors used to compute base risk;
- **RiskReductionLevel** and **CostMetrics** capture residual risk and economic consequences after the application of controls;
- **HumanFactorMetric** aggregates socio-technical indicators such as phishing outcomes, policy violations, and awareness-training completion.

Each association in the metric layer is annotated with a verb (*evaluates*, *assesses*, *quantifies*, or *captures*) and is linked to a Goal–Question–Metric (GQM) entry, enabling machine-readable traceability between standards, metrics, and controls. A complete XMI export of the UML schema is provided in the public repository.

Conceptual UML: standards-traceable evidence model

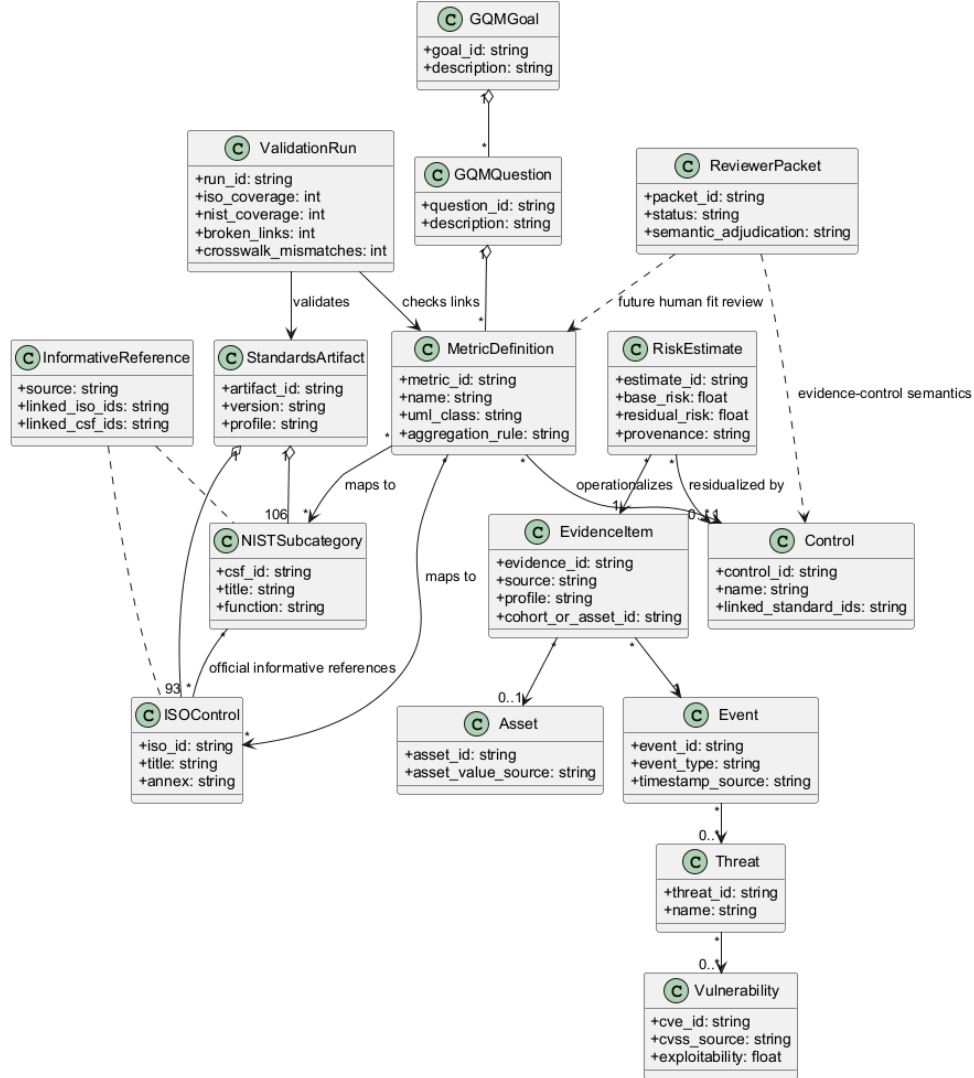


Figure 2: Conceptual UML layer for the standards-traceable evidence model. It links standards artifacts, GQM questions and metrics, evidence items, risk estimates, controls, and structural validation runs.

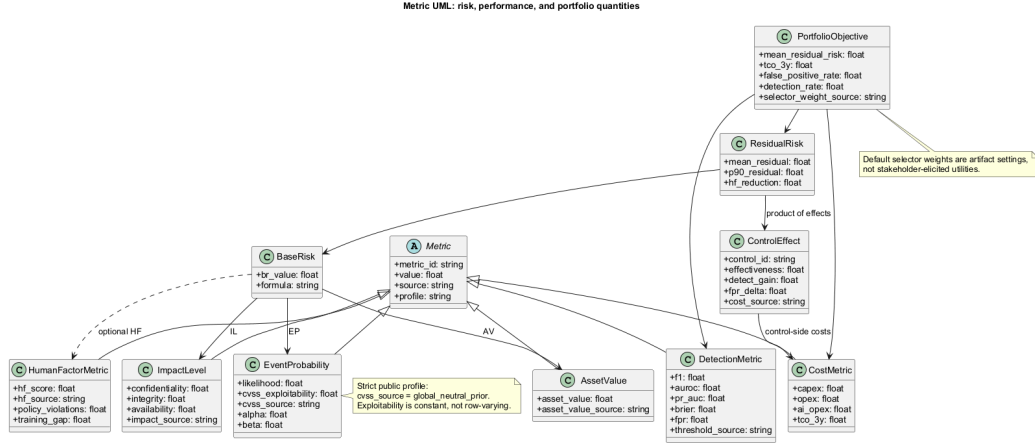


Figure 3: Metric UML layer for risk, performance, and portfolio quantities. Source fields distinguish telemetry-derived values, neutral public-data priors, optional human-factor overlays, scenario-analytic control effects, and artifact-default selector weights.

2.3. Traceable Risk Transformation and Downstream Portfolio Comparison

This layer performs the traceable transformation from represented cybersecurity evidence to governance-relevant quantitative risk variables. The formulation combines asset value, event probability, technical impact, and optional human-factor terms in a manner that remains compatible with ISO/IEC 27001, ISO/IEC 27005, and NIST CSF 2.0, while preserving the distinction between telemetry-derived evidence and downstream enrichment variables used for risk and portfolio analysis. In deployment settings, these enrichment terms can be populated from asset registers, curated CVE/CVSS manifests, and observed human-factor overlays. In the strict public-data profile reported here, however, the non-telemetry terms are only partially activated: asset value is instantiated through a tagged telemetry proxy, CVSS-based exploitability falls back to a neutral prior, and the human-factor overlay remains inactive. Table 1 defines which risk factors are empirically activated in the strict public-data profile and which factors are represented only as provenance-preserving extension hooks. Accordingly, the reported experiment should not be read as a full validation of the complete AV–EP–IL–HF risk formulation. The public run therefore validates the telemetry-derived evidence path and representation logic rather than a full empirical activation of all downstream factors.

Table 1: Risk-factor activation status in the strict public-data profile.

Risk factor	Public-profile implementation	Empirical status	Permitted claim
AV	Telemetry-derived source-cohort proxy	Proxy only; no verified enterprise asset register	Representation and proxy demonstration
EP telemetry likelihood	IDS/anomaly score from flow-derived features	Empirically activated	Telemetry-derived likelihood path demonstrated
EP exploitability / CVSS	Global neutral prior	Constant; no row-varying CVE/CVSS linkage	Extension hook represented, not validated
IL	Catalog/scenario-based impact scaling	Scenario assumption	Scenario-analysis demonstration only
HF	HF:none	Inactive; no observed HF overlay	HF slot represented, not empirically validated
Device identity	Source-file cohort	Surrogate; no row-level device attribution	Cohort-level provenance only
Time	Synthesized ordering	Surrogate; no true wall-clock chronology	Ordered hold-out demonstration only
Control effectiveness	Configurable coefficients	Planning assumption; not measured intervention effect	Portfolio scenario exploration only

Asset value.. Each asset i has a raw monetary valuation $\tilde{v}_i \geq 0$ obtained either from an asset register or, in public-data profiles without business valuations, from a tagged proxy source. A normalized asset-value factor

$$AV_i = \frac{\tilde{v}_i - \min(\tilde{v})}{\max(\tilde{v}) - \min(\tilde{v})} \quad (1)$$

is used in the risk score, where the denominator spans the valuation range of the considered assets.

Event probability. For each event type j (e.g., an attack family or exploitation scenario), event probability is expressed as

$$\text{EP}_j = \sigma(\alpha \text{likelihood}_j + \beta \text{exploitability}_j), \quad \sigma(x) = \frac{1}{1 + e^{-x}}, \quad (2)$$

where likelihood_j is derived from telemetry and historical frequency indicators, and exploitability_j is derived from CVSS-based vulnerability attributes (e.g., attack vector and complexity). In enriched deployment profiles where exploitability varies across observations, coefficients α and β can be fitted by logistic regression on labeled historical events. In the strict public-data profile reported here, however, all rows carry the same `global_neutral_prior` CVSS tag, so exploitability_j is constant across the evaluation set. The reported public run should therefore be read as a telemetry-driven calibration of the likelihood term within the EP architecture, not as a full empirical validation of a row-varying multi-factor exploitability component.

Impact level with human factors. For each scenario k associated with an event, confidentiality, integrity, and availability impacts are represented as normalized scores $e_{Ck}, e_{Ik}, e_{Ak} \in [0, 1]$ derived from CVSS impact metrics. A human-factor term $\text{HF}_k \in [0, 1]$ summarizes socio-technical indicators such as phishing-simulation failure ratios, policy-violation densities, and training/culture indices; higher values indicate higher residual socio-technical risk. The combined impact level is

$$\text{IL}_k = w_C e_{Ck} + w_I e_{Ik} + w_A e_{Ak} + w_H \text{HF}_k, \quad w_C + w_I + w_A + w_H = 1, \quad (3)$$

where (w_C, w_I, w_A, w_H) are governance-defined weights. Operational details and an extended human-factor synthesis protocol are documented in the public repository.

Base risk and expected loss. Within the transformation layer, the represented evidence factors are combined into auditable base-risk and expected-loss quantities. The base risk associated with asset i , event j , and scenario k is defined as

$$\text{BR}_{ijk} = \text{AV}_i \cdot \text{EP}_j \cdot \text{IL}_k. \quad (4)$$

In monetary terms, the corresponding expected loss is

$$\mathbb{E}[\text{Loss}_{ijk}] = \tilde{v}_i \cdot \text{EP}_j \cdot \text{IL}_k. \quad (5)$$

Portfolio-level expected loss over a planning window W (e.g., one quarter) aggregates Eq. (5) across assets, events, and scenarios using exposure multipliers and scenario weights; the full expression is given in Appendix Appendix A.

Residual risk and cost.. For a given control portfolio K , the transformation layer also produces downstream decision variables describing residual risk and control-side cost. Each control $m \in K$ has an effectiveness coefficient $\eta_m \in [0, 1]$ that reflects the fraction of risk addressed by that control under the modeled conditions. A human-factor reduction coefficient $\eta_H \in [0, 1]$ captures the effect of awareness and culture interventions. In the shared artifact, these control effectiveness and cost terms are configurable scenario-analytic defaults stored in `control_catalog.csv`; they should be interpreted as transparent planning assumptions rather than as intervention effects estimated from the public CIC IoT 2023 release.

$$\text{ResidualRisk}(K) = \text{BR}_{ijk} (1 - \eta_H) \prod_{m \in K} (1 - \eta_m). \quad (6)$$

The associated risk-reduction level is

$$\text{RRL}(K) = \frac{\text{BR}_{ijk} - \text{ResidualRisk}(K)}{\text{BR}_{ijk}}. \quad (7)$$

The three-year control-side Total Cost of Ownership of portfolio K is decomposed into capital and recurring operating expenditures:

$$\text{TCO}_{3y}^{\text{ctrl}}(K) = \text{CapEx}_K + 3 \text{OpEx}_K + 3 \text{OpEx}_K^{\text{AI}}, \quad (8)$$

where $\text{OpEx}_K^{\text{AI}}$ includes compute, storage, and staffing costs required by the AI components. Hidden-loss terms are not estimated from the public CIC IoT 2023 release and are therefore kept outside the strict reported TCO metric.

Downstream portfolio-comparison constraint and objectives.. At the downstream decision-support stage, security investment is constrained by a Gordon–Loeb bound [9]:

$$\sum_{m \in K} \text{CapEx}_m \leq \gamma \mathbb{E}[\text{Loss}]_W, \quad \gamma \approx 0.37, \quad (9)$$

where $\mathbb{E}[\text{Loss}]_W$ denotes the aggregated expected loss over window W . Optional asset-level and rolling-window variants are defined in Appendix Appendix A.

For downstream portfolio comparison, the framework evaluates each feasible portfolio through a four-objective vector:

$$\mathbf{f}(K) = (f_1, f_2, f_3, f_4) = (\text{ResidualRisk}(K), \text{TCO}_{3y}^{\text{ctrl}}(K), \text{FPR}, -\text{DR}), \quad (10)$$

where DR (detection rate) and FPR (false-positive rate) are portfolio-level scenario metrics initialized from the underlying intrusion-detection models and adjusted by control-catalog deltas. In the present architecture, NSGA-II [23] is used as a downstream portfolio-comparison mechanism rather than as the primary representation artifact itself. Using a binary decision vector $\mathbf{x} \in \{0, 1\}^M$, where $x_m = 1$ selects control m , the procedure approximates a feasible trade-off frontier under the constraint (9). A concise pseudo-code listing is retained in Algorithm 1; full hyperparameter grids and sensitivity analyses are moved to Appendix Appendix A.

Algorithm 1 NSGA-II as a downstream portfolio-comparison procedure under the Gordon–Loeb bound

Require: Initial population size P , number of generations G , control universe $\{1, \dots, M\}$, Gordon–Loeb budget B .

- 1: Initialize population $\mathcal{P}_0$ of binary portfolios satisfying Eq. (9).
 - 2: **for** $t = 0$ to $G - 1$ **do**
 - 3: Evaluate objectives $\mathbf{f}(K)$ for all $K \in \mathcal{P}_t$ via Eqs. (6)–(10).
 - 4: Apply non-dominated sorting and crowding-distance assignment.
 - 5: Select parents by binary tournament on (rank, crowding distance).
 - 6: Apply crossover and mutation to generate offspring; repair GL-violating portfolios to satisfy Eq. (9).
 - 7: Form $\mathcal{P}_{t+1}$ by merging parents and offspring and keeping the best P individuals.
 - 8: **end for**
 - 9: **return** Approximate Pareto front from the final population.
-

2.4. Datasets and Preprocessing

The framework is instantiated on heterogeneous IoT telemetry enriched with vulnerability information. Two primary data sources are used: the

CIC IoT 2023 dataset for network flows and the NVD vulnerability feed for CVE attributes.

CIC IoT 2023.. CIC IoT 2023 [1, 2] is a large-scale benchmark for intrusion detection in IoT environments. The corpus includes traffic from 105 IoT devices, covering benign activity and 33 attack scenarios grouped into seven categories (DDoS, DoS, reconnaissance, web, brute-force, spoofing, and Mirai variants). Each bidirectional flow is represented by statistical and protocol features such as duration, packet and byte counts, packet rates, TCP flag counts, and application/transport protocol indicators.

In the present study, flows are labeled as benign or malicious according to the original scenario annotations. The reported resource-aware evaluation ingests all 63 members of the merged CSV release with a uniform 1,000-row cap per member, yielding 63,000 raw rows across 63 source files and 33 event types. Because the public CSV release does not expose victim-device identifiers, the strict artifact run treats each merged member as a *source-file cohort* rather than a verified physical device. Missing timestamps are synthesized when absent; numeric flow statistics are retained in their original numeric form; telemetry-only windows are constructed for IDS training; and missing numeric values are imputed. asset values are not read from an enterprise register in this public profile; instead, a telemetry-derived asset-value proxy is derived from per-cohort traffic statistics and tagged as `asset_value_source=telemetry_proxy`. The official victims inventory is preserved as side-car metadata, but it cannot be joined to the public CSV rows because those rows do not encode victim-device identifiers. Raw rows are first partitioned into training, validation, and test segments; because the public profile uses source-file cohorts as surrogate assets, split boundaries are aligned to cohort changes before window construction so that neither raw flows nor windowed samples straddle partitions. Windowing then produces 61,488 samples using 25-flow windows per cohort, with 44 source-file cohorts in training, 10 in validation, and 9 in test. This design preserves boundary safety for telemetry-derived evidence generation, but it does not by itself supply verified asset-level business values, device-level CVE joins, or observed organizational human-factor measurements.

NVD vulnerability feed.. The NVD `nvdCVE-1.1` JSON feeds (API v2) [24] provide CVE identifiers, textual descriptions, CVSS v3.1 base metrics, and affected configurations. The implemented artifact accepts event-level, asset-level, or asset+timestamp-level CVE maps. However, event-level joins are

label-derived on the public CIC IoT 2023 release and therefore leak attack identity if used in headline evaluation. The strict reported profile disables such event-only surrogates and only admits curated asset- or timestamp-level joins; when those are unavailable, all rows fall back to a global neutral CVSS prior tagged as `cvss_source=global_neutral_prior`. In the reported strict public profile, this fallback applies to every row, so exploitability_j is constant across the evaluation set. The public run therefore preserves the exploitability field for provenance and downstream compatibility, but it does not empirically identify a row-varying CVSS effect in Eq. (2). These attributes feed into the event-probability and impact-level components in Eqs. (2) and (3). Vulnerability records are linked to the UML entities `Vulnerability`, `Event`, and `ImpactLevel`. Device-level attribution remains possible only when a curator can provide a compatible per-asset manifest external to the public CSV release.

Preprocessing pipeline. Figure 4 sketches the end-to-end ingestion and decision pipeline. Raw CIC IoT 2023 flow files are first ingested, then transformed into UML-aligned instances with provenance tags. The implemented artifact normalizes column names, synthesizes timestamps when needed, records provenance for cohort identifiers, asset values, CVSS sources, and human-factor overlays, imputes missing numeric values, partitions raw rows before any window construction, and then builds rolling windows using mean/std/last-value telemetry summaries. Crucially, the telemetry-only configuration excludes asset-value, CVSS, and human-factor columns from the IDS feature matrix; these fields are preserved only in the metadata consumed by the downstream risk layer. In the strict public-data profile, that metadata records non-telemetry terms as proxies, neutral priors, or inactive overlays rather than as empirically observed factors. Where required by specific models, telemetry features are additionally standardized within the training partition. The same split logic is reused for all models and baselines to ensure comparability.

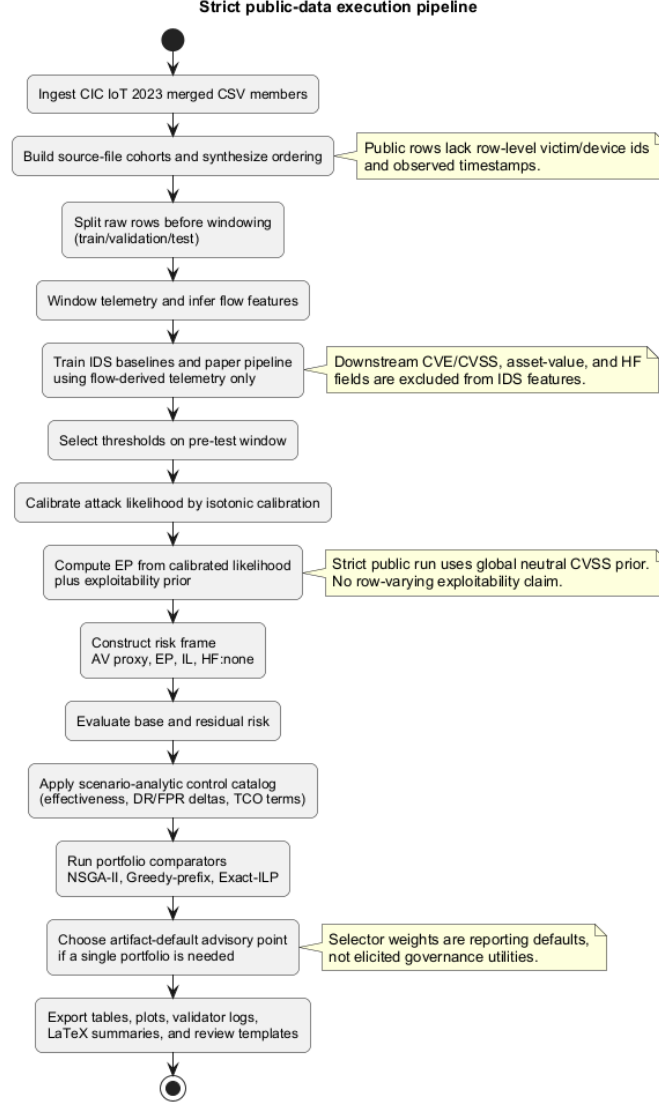


Figure 4: Strict public-data execution pipeline from raw IoT telemetry through leakage-safe IDS training, calibrated likelihood estimation, source-tagged risk construction, scenario-analytic portfolio comparison, and reporting exports.

2.5. Machine-Learning Pipeline

2.5.1. Classifier-Agnostic Telemetry Evidence Interface

The framework does not require a specific IDS architecture. A telemetry scorer is treated as an evidence generator if it provides: (i) an asset or

source-cohort identifier, (ii) a timestamp or surrogate ordering index, (iii) a calibrated maliciousness or anomaly score, (iv) a thresholded alert label when needed, and (v) provenance metadata linking the score to the input feature window and model configuration.

2.5.2. *Artifact-Default Telemetry Scorer*

The AI layer combines an unsupervised neural anomaly detector with a supervised gradient-boosted risk scorer. The aim is to convert raw flow telemetry into calibrated attack-likelihood estimates and then combine those estimates with separately curated risk metadata in a standards-aligned risk layer that supports downstream portfolio comparison. The resulting pipeline is presented as one telemetry-only operationalization of the artifact, not as a claim that it is the strongest standalone classifier among all tested baselines.

LSTM-based anomaly detection.. Temporal patterns of benign traffic are modeled with a Long Short-Term Memory (LSTM) network [25]. Input sequences consist of fixed-length windows of numeric flow features per asset (25-flow windows in the reported resource-aware profile). The implemented detector is a two-layer LSTM regressor followed by a small feed-forward head; it is trained only on benign windows to predict the final feature vector in each sequence using mean-squared error and the Adam optimizer [26]. The per-window anomaly signal is the prediction error between the forecasted and observed last-step vectors; this signal is min–max scaled on the pre-test window and contributes to the likelihood_j term in Eq. (2).

Gradient-boosted risk scorer.. A gradient-boosted decision-tree ensemble implemented with XGBoost [27] estimates a calibrated attack-probability signal

$$\Pr\{\text{Attack} \mid \text{Event}, \text{Asset}\},$$

using a feature set that includes LSTM anomaly scores and windowed flow statistics only. CVSS attributes, asset values, and human-factor indicators are intentionally excluded from this classifier feature set to prevent label leakage from downstream enrichment artifacts. Hyperparameters such as tree depth, learning rate, and number of estimators are selected on the training+validation window using forward-chaining, group-aware cross-validation [28]. Probability calibration is then performed with isotonic regression [29] fitted on out-of-fold pre-test scores, yielding calibrated outputs for the held-out test window. The generic event-probability architecture

in Eq. (2) allows α and β to be fitted with a no-intercept logistic regression on the same pre-test partition, with exploitability terms coming from the post-classification risk metadata rather than from the IDS feature matrix. In the reported strict public-data profile, however, those exploitability terms are constant because every row carries the same neutral CVSS prior. Accordingly, the fitted β contributes only a constant-offset term in the public run and should not be interpreted as evidence that a row-varying exploitability effect has been empirically learned or validated.

Cross-validation and calibration.. All models—including baselines—share the same ordered train/validation/test partitions. Model selection uses a five-fold, group-aware, time-series cross-validation: in each fold, the validation slice occurs strictly after the training slice; groups are defined by asset identifiers; and no shuffling is used. In the reported resource-aware profile, these group identifiers correspond to source-file-level assets derived from the 63 merged CIC IoT 2023 members. Classification metrics and risk-based quantities are reported on the untouched test window described in Section 3.1. The detailed cross-validation protocol and alternative IDS baselines appear in Section 3.2 and Appendix Appendix A.

Integration with optimization.. For each candidate control portfolio K , the calibrated risk outputs are aggregated into $\text{ResidualRisk}(K)$ using Eq. (6), and the corresponding three-year control TCO is computed via Eq. (8). These values instantiate the objective vector $\mathbf{f}(K)$ in Eq. (10), which NSGA-II optimizes subject to the Gordon–Loeb constraint (9). The same scenario-analytic risk and cost definitions are used for all portfolios, allowing controlled comparison between artifact configurations and the algorithmic/economic baselines described in Section 3.2.

GQM and standards traceability (pointer).. Each metric used in the risk formulation and optimization is registered in a Goal–Question–Metric matrix and mapped to one or more ISO/IEC 27001 Annex A controls and NIST CSF 2.0 subcategories. Section 3.6 and Section 3.7 describe this mapping and the associated validator; full machine-readable artifacts are included in Appendix Appendix A.

3. Results

Table 1 defines which risk factors are empirically activated in the strict public-data profile and which factors are represented only as provenance-

preserving extension hooks. Accordingly, the reported experiment should not be read as a full validation of the complete AV–EP–IL–HF risk formulation. The empirically activated path is the telemetry-derived likelihood component, while CVSS exploitability, verified asset value, human-factor effects, and measured control effectiveness remain outside the strict public profile. The CVSS and asset-value provenance tables are included in the artifact to prevent overclaiming: they show that the strict public profile uses a global neutral CVSS prior and telemetry-proxy asset values rather than verified row-level exploitability and enterprise asset-register data.

3.1. Performance Metrics

For every prediction, true positives (TP), false positives (FP), true negatives (TN), and false negatives (FN) are counted. From these, the standard classification metrics are reported as

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN}, \quad (11)$$

$$\text{Precision} = \frac{TP}{TP + FP}, \quad (12)$$

$$\text{Recall (DR)} = \frac{TP}{TP + FN}, \quad (13)$$

$$F_1 = \frac{2 \text{Precision Recall}}{\text{Precision} + \text{Recall}}, \quad (14)$$

$$\text{FPR} = \frac{FP}{FP + TN}. \quad (15)$$

Together with the area under the ROC curve (ROC–AUC). All rates are in the $[0, 1]$ interval; higher values indicate better performance except for (15), where lower is better.

3.2. Baselines

Two baseline families are reported in addition to governance/economic comparators (FAIR, GL, OCTAVE, COSO).

(I) Algorithmic IDS baselines. All models ingest the same features/splits as the pipeline in Section 2.4; windowed models use the 25-flow window per asset in the reported resource-aware profile. Thresholds are selected on the validation window by maximizing F_1 (ties $\rightarrow$ higher Recall); probabilistic outputs are *isotonic-calibrated* before thresholding. The reported resource-aware profile uses the compact settings shown in Table 2.

- **OC-SVM (RBF)**—unsupervised; train on benign-only; compact grid $\nu = 0.05$, $\gamma \in \{1/d, 2/d\}$ where d is feature count.
- **Isolation Forest**—unsupervised; 200 trees; contamination fixed at 0.05; `max_samples`= 256.
- **LSTM Autoencoder**—unsupervised; hidden size 48, bottleneck 24; Adam 10^{-3} , 8 epochs; anomaly score = reconstruction error.
- **Random Forest**—supervised; `n_estimators`= 400, `max_depth`= 24, `max_features`= $\sqrt{d}$.
- **LightGBM**—supervised; 31 leaves, depth 12, learning rate 0.05, 400 trees.
- **1D-CNN**—supervised; input $(25, d)$; two Conv1D blocks (64/128, kernel 3), global average pooling, dense[128], sigmoid; Adam 10^{-3} , 8 epochs, dropout 0.3.

Table 2: Algorithmic IDS baselines: training regime and compact settings used by the reported resource-aware profile.

Model	Regime	Key settings / tuned ranges
OC-SVM (RBF)	Unsupervised (benign-only)	$\nu = 0.05$; $\gamma \in \{1/d, 2/d\}$
Isolation Forest	Unsupervised (benign-only)	200 trees; contamination= 0.05; <code>max_samples</code> =256
LSTM-AE	Unsupervised (benign-only)	Hidden size 48; bottleneck 24; Adam 10^{-3} ; 8 ep
Random Forest	Supervised	400 trees; depth= 24; <code>max_features</code> = $\sqrt{d}$
LightGBM	Supervised	31 leaves; depth= 12; lr= 0.05; 400 trees
1D-CNN	Supervised (window)	Two Conv1D blocks (64/128, $k=3$); GAP; Dense[128]; sigmoid; dropout 0.3; 8 ep

(II) *Optimization baselines.* NSGA-II is compared against: (a) a greedy prefix-frontier heuristic and (b) an exact ε -constraint method that produces Pareto points by solving a 0–1 ILP in log-space. All methods enforce the *portfolio-level* GL bound (Eq. 9) and are compared on the common (ResidualRisk, $\text{TCO}_{3y}^{\text{ctrl}}$) plane. The earlier auxiliary DR/FPR policy thresholds are not enforced in the reported frontier comparison because the strict public profile’s base FPR is already above the illustrative 0.05 target; the artifact instead exports `out/real/optimization_policy_constraints.csv` documenting the disabled thresholds and catalog-reachable metric extremes. Comparison metrics are best achieved mean/p90 ResidualRisk, CapEx, three-year control TCO, *hypervolume* (HV), Pareto set size, and wall-clock runtime. The greedy and ILP procedures are detailed in Section 3.2.

Table 3: Contextual telemetry evidence-generation baselines on the ordered, boundary-safe test window ($N=8784$ windows; attack-dominant: $\approx 97.4\%$ malicious). F_1 and AUROC are complemented by specificity and class-imbalance-sensitive metrics. All thresholds selected on the pre-test window; isotonic calibration applied. The framework is model-agnostic; LightGBM attains the best raw classification metrics, whereas the artifact-default scorer is used only to instantiate the end-to-end evidence-to-risk pipeline.

Model	F_1	AUROC	Specificity	Bal. Acc.	MCC	FA/1000
Random Forest	0.995	0.995	0.712	0.855	0.789	287.6
LightGBM	0.996	0.998	0.836	0.916	0.842	163.7
1D-CNN	0.990	0.968	0.389	0.693	0.524	610.6
OC-SVM	0.992	0.987	0.743	0.867	0.702	256.6
Isolation Forest	0.988	0.817	0.124	0.561	0.300	876.1
LSTM-AE	0.987	0.500	0.000	0.500	0.000	1000.0

Note: The test split is *attack-dominant* ($\approx 97.4\%$ malicious windows); therefore F_1 and PR-AUC alone are insufficient and are supplemented by specificity (TNR), balanced accuracy, MCC, and false alarms per 1,000 benign flows. The artifact-default telemetry scorer is not claimed to dominate all IDS baselines; LightGBM slightly exceeds it on raw classification metrics. The retained contribution is the traceable evidence chain and downstream standards-linked representation rather than classifier superiority. The artifact-default scorer at the validation-selected (default 0.5) threshold obtains $F_1=0.995$, AUROC= 0.997, PR-AUC= 1.000, Brier= 0.006, and FPR= 0.208, corresponding to approximately 208 false alarms per 1,000 benign windows. Under the pre-test fixed-FPR operating-point protocol (targeting nominal 1% FPR), the realized hold-out FPR falls to 0.0044 with detection rate 0.982. These two figures correspond to *different thresholding protocols* and are not directly interchangeable; both are reported in `out/real/confusion_matrix.csv` and `out/real/fixed_fpr_operating_points.csv`.

Optimization Baselines

Greedy heuristic (risk-reduction per cost).. At each step, select the control with the largest marginal $\Delta\text{RRL}/\Delta\text{CapEx}$ under feasibility (GL bound and already-chosen set). Marginals are recomputed after each pick to account for interaction via Eq. (6).

Algorithm 2 Greedy selection under GL bound

Require: Candidate controls $\{1 \dots M\}$ with effectiveness η_m and CapEx_m ; portfolio budget $B = \gamma \mathbb{E}[\text{Loss}]_W$; base risk BR from Eq. (4).

- 1: $K \leftarrow \emptyset, C \leftarrow 0$
- 2: **while** true **do**
- 3: For each feasible $m \notin K$ with $C + \text{CapEx}_m \leq B$, compute current $\text{RR}(K) = \text{ResidualRisk}(K)$ and candidate $\text{RR}(K \cup \{m\})$ via Eq. (6)
- 4: $\Delta_m \leftarrow \frac{\text{RR}(K) - \text{RR}(K \cup \{m\})}{\text{CapEx}_m + 3(\text{OpEx}_m + \text{OpEx}_m^{\text{AI}})}$
- 5: **if** no feasible m **then break**
- 6: **else** pick $m^* = \arg \max_m \Delta_m$; $K \leftarrow K \cup \{m^*\}$; $C \leftarrow C + \text{CapEx}_{m^*}$
- 7: **end if**
- 8: **end while**
- 9: **return** all non-dominated prefixes observed during the greedy construction

The artifact reports the non-dominated prefixes observed during this construction rather than only the terminal set. This makes the HV comparison a frontier-level comparison rather than a many-point method versus single-point heuristic comparison.

Exact ε -constraint via 0-1 ILP (log-space).. With binary decision $x_m \in \{0, 1\}$, Eq. (6) factorizes as $\text{ResidualRisk}(K) = \text{BR}(1 - \eta_H) \prod_m (1 - \eta_m)^{x_m}$. Taking logs gives

$$\log \text{ResidualRisk} = \underbrace{\log(\text{BR}(1 - \eta_H))}_{\text{constant}} + \sum_m x_m \log(1 - \eta_m),$$

which is *linear* in x_m . For a grid of risk levels $\tau \in \mathcal{T}$ the following problem is solved:

$$\min_{x \in \{0,1\}^M} \text{TCO}_{3y}^{\text{ctrl}}(x) = \sum_m x_m (\text{CapEx}_m + 3 \text{OpEx}_m + 3 \text{OpEx}_m^{\text{AI}}) \quad (16)$$

$$\text{s.t.} \quad \sum_m x_m \text{CapEx}_m \leq \gamma \mathbb{E}[\text{Loss}]_W \quad (\text{GL bound; Eq. 9}) \quad (17)$$

$$\log(\text{BR}(1 - \eta_H)) + \sum_m x_m \log(1 - \eta_m) \leq \log \tau \quad (\text{risk cap}) \quad (18)$$

$$x_m \in \{0, 1\} \quad \forall m.$$

Sweeping τ yields a set of *Pareto-optimal* points on $(\text{ResidualRisk}, \text{TCO}_{3y}^{\text{ctrl}})$; dominated points are discarded. Optional linear policy constraints $\text{DR}(x) \geq \underline{d}$ and $\text{FPR}(x) \leq \bar{f}$ are implemented, but they are disabled in the reported strict public profile so that NSGA-II, Greedy, and Exact-ILP are compared on the same frontier plane without a configuration-induced infeasibility.

3.3. Cross-Validation and Significance Testing

Model selection employed a *five-fold, group-aware time-series cross-validation* (GTS-CV) on the training+validation window. Folds respected temporal order via forward chaining: in each fold, the validation slice occurs strictly after the training slice in time. Groups were defined by asset/device identifiers; group boundaries did not straddle folds (preventing cross-asset leakage). No stratification or shuffling was applied. Hyperparameters were chosen by maximizing the mean validation score across the five folds, and the final models were retrained on the full 85% pre-test window with those settings.

Final metrics (Accuracy, Precision, Recall/DR, F_1 , FPR, AUROC), Residual Risk, and control-side TCO were computed once on the untouched ordered test set (last 15% target share before boundary alignment). Pairwise method comparisons used the Wilcoxon signed-rank test on per-time-block metric series; $p < 0.05$ was considered significant. Effect sizes were summarized with Cliff’s δ . For IDS baselines, unsupervised models are trained on the benign subset of each training fold and thresholded on the subsequent validation slice; supervised models follow the same forward-chaining CV as the main pipeline with isotonic calibration fitted only on validation. For optimization baselines, hypervolume (HV) is computed on the

(ResidualRisk, $\text{TCO}_{3y}^{\text{ctrl}}$) plane with a reference point slightly above the worst observed frontier cost. The released artifact also exposes a default advisory selector that chooses one frontier point by a normalized composite score with weights 0.40 on mean residual risk, 0.25 on control-side TCO, 0.20 on FPR, and 0.15 on DR. These weights are artifact-default reporting settings rather than elicited governance utilities. Robustness is checked by one-at-a-time $\pm 20\%$ perturbation of each weight with renormalization to unit sum.

3.4. Ablation: Human-Factor Weight w_H

The human-factor term is ablated by sweeping $w_H \in \{0, 0.10, 0.20, 0.30\}$ while freezing the portfolio-level GL budget at the $w_H=0$ bound (Section 2.3). Table 4 summarizes detection metrics and residual-risk outcomes on the held-out test window. Because the strict public-data profile contains no observed or simulated HF overlay (HF:none throughout), the ablation is intentionally flat: changing w_H does not alter the reported residual-risk values. The HF ablation is intentionally flat because the strict public profile contains no observed human-factor overlay. Therefore, this table verifies implementation behavior under HF:none; it does not evaluate organizational human-factor effects.

Table 4: Ablation on the human-factor weight w_H . Metrics on the ordered test window; CapEx budget fixed at the $w_H=0$ GL bound.

w_H	F ₁	AUROC	ResidualRisk (mean)	ResidualRisk (p90)
0.00	0.995	0.997	0.010	0.019
0.10	0.995	0.997	0.010	0.019
0.20	0.995	0.997	0.010	0.019
0.30	0.995	0.997	0.010	0.019

Note: In the reported strict public-data profile, all rows are tagged HF:none; the flat ablation confirms that the artifact no longer fabricates human-factor sensitivity when no HF telemetry is available.

3.5. Total Cost of Ownership (TCO)

Economic efficiency is captured by the *control-side* three-year Total Cost of Ownership. On the strict public-data profile, only costs that can be attributed directly to selected controls are reported:

$$\text{TCO}_{3y}^{\text{ctrl}} = \text{CapEx} + 3 \times (\text{OpEx} + \text{OpEx}^{\text{AI}}).$$

This choice removes the earlier dependence on scenario-specific usage CSVs and ties the reported cost directly to the selected portfolio. Hidden-loss terms are discussed qualitatively but are not estimated from the public CIC IoT 2023 release.

Table 5: Summary of key results mapped to the research questions for the reported resource-aware profile (ordered, boundary-safe test window; fixed split & seeds).

RQ	Evaluation axis	Outcome (% or absolute)
RQ1	Schema $\leftrightarrow$ standards alignment	UML/XMI and GQM artifacts encode assets, threats, vulnerabilities, events, controls, and metric classes in machine-readable form; 93/93 ISO rows and 106/106 CSF rows are represented in the released artifact.
RQ2	Coverage and integrity validation	93/93 ISO 27001 controls & 106/106 CSF 2.0 subcats auto-mapped; 100% coverage confirmed by the automated CSV/XMI validator (0.11 s in the regenerated run), with 0 broken links, duplicate rows, or dangling rows in the reported validator output.
RQ2	Official ISO $\leftrightarrow$ NIST informative-reference consistency	Official NIST informative-reference crosswalk reproduced bidirectionally in the artifact; validator reports 0 ISO $\leftrightarrow$ NIST informative-reference mismatches across all mapped rows.
RQ2	Scope of mapping validation	Structural: coverage, identifier consistency, broken-link checks, duplicate/dangling-row checks, and bidirectional ISO $\leftrightarrow$ NIST crosswalk consistency are verified by the automated validator. The artifact is presented as an inspectable standards-traceability baseline, not as a compliance oracle.
RQ3	Telemetry evidence-generation performance	The artifact-default telemetry scorer obtains $F_1=0.995$, AUROC=0.997, PR-AUC=1.000 (Brier score = 0.006) . Baseline comparison confirms LightGBM slightly exceeds these metrics, supporting the model-agnostic framing of the framework.

Continued on next page

RQ	Evaluation axis	Outcome (% or absolute)
RQ3	EP exploitability activation status	Not empirically activated as a varying factor in the strict public-data profile. All 61,488/61,488 reported rows carry <code>cvss_source=global_neutral_prior</code> , so Eq. (2) is exercised as a telemetry-driven likelihood calibration with a constant exploitability offset rather than as a test of row-varying CVSS-based exploitability.
RQ3	Frontier-level portfolio exploration	NSGA-II returns a 61 -point feasible frontier with HV= 31,436.9 ; Greedy returns a 14 -point prefix frontier with HV= 30,810.2 ; Exact-ILP returns a 16 -point frontier with HV= 28,970.3 .
RQ3	Artifact-default advisory selection	Under the released artifact-default weights (0.40, 0.25, 0.20, 0.15), the selected NSGA-II point yields 4.5% lower mean residual risk and 4.5% lower 90th-percentile residual risk with 5.0% higher three-year control TCO relative to the matched-budget Greedy comparator.
RQ3	Selection-weight robustness	One-at-a-time $\pm 20\%$ perturbations of the advisory weights preserve the default selection in 6/8 cases and produce 2 unique portfolios across the 9 tested settings. The selected mean residual risk spans 0.008335–0.009725 and three-year control TCO spans 394,900–415,200 .
RQ4	Reporting-facing export provisioning	The released artifact provisions validator outputs, tables, plots, and schema-linked CSV/L ^A T _E X summaries that preserve links from standards entries to metrics, residual-risk decompositions, and control-side TCO contributions in reporting-facing form.
RQ4	Empirical governance reuse status	Not established in the strict public-data profile. No auditor walkthrough, user evaluation, BI/dashboard deployment, or API/tool-integration study is reported; the artifact evidence stops at export-layer provisioning.

Sensitivity Analysis ($\pm 20\%$)

Setup. The strict artifact perturbs the scenario-analytic control-catalog cost components $\{\text{CapEx}, \text{OpEx}, \text{OpEx}^{\text{AI}}\}$ one-at-a-time by $\pm 20\%$. For each perturbation, three-year control TCO is recomputed for the matched-budget Greedy portfolio and for the NSGA-II portfolio. Improvement is reported as

$$\Delta_{\%} = \frac{\text{TCO}^{\text{base}} - \text{TCO}^{\text{NSGA}}}{\text{TCO}^{\text{base}}} \times 100.$$

A joint perturbation ("All parameters") scales all three cost terms by the same factor. Negative values indicate that the artifact-default NSGA-II selection has higher three-year control TCO than the matched-budget Greedy comparator under that perturbation.

Table 6: Sensitivity of three-year TCO improvement to $\pm 20\%$ unit-cost variation.

Varied parameter	$\Delta_{\%}$ @ -20%	$\Delta_{\%}$ @ $+20\%$
CapEx	-5.18	-4.83
Control OpEx	-4.93	-5.03
AI OpEx	-4.86	-5.10
All parameters (joint)	-4.98	-4.98

Portfolio-selection weight sensitivity. The $(0.40, 0.25, 0.20, 0.15)$ selector is retained only as the released artifact’s default advisory rule; it is not claimed as an elicited governance utility function. To check local robustness, each weight is perturbed one-at-a-time by $\pm 20\%$ and the four weights are then renormalized to unit sum before reselecting a point from the NSGA-II frontier. Across the resulting 8 perturbations plus the default setting, the default selection is preserved in 6/8 perturbations and only 2 unique portfolios are selected overall. The selected mean residual risk ranges from 0.008335 to 0.009725, while three-year control TCO ranges from 394,900 to 415,200. The selector shifts to the cheaper but riskier portfolio when the TCO weight is increased by 20% or the mean-residual-risk weight is decreased by 20%; otherwise the default point is recovered. The scientific result should therefore be read at the frontier level, while the single recommended point should be interpreted as a locally stable artifact-default advisory choice.

Reproduction. The public repository provides the driver and parameter files:

```

cd ai_risk
# Precomputed results are provided here:
#   out/real/tco_sensitivity_full.csv
#   out/real/portfolio_weight_sensitivity.csv
# To regenerate, rerun the real profile and perturb either
# the control-side CapEx / OpEx / AI-OpEx terms or the
# artifact-default advisory weights.

```

Schema: `control_catalog.csv` stores scenario-analytic `capex`, `opex`, and `ai_opex` assumptions per control; the reported `out/real/tco\_sensitivity\_full.csv` file is generated by perturbing those terms for the advisory NSGA-II and Greedy portfolios. The reported `out/real/portfolio\_weight\_sensitivity.csv` file records the one-at-a-time $\pm 20\%$ perturbations of the artifact-default selector weights and the resulting selected portfolios.

3.6. Goal-Question-Metric Mapping

This section summarizes the construction of the Goal-Question-Metric (GQM) matrix used in the framework. High-level governance and security goals are derived from ISO/IEC 27001:2022 Annex A controls and NIST CSF 2.0 subcategories. Each goal is decomposed into concrete questions (for example, “How effectively are access controls preventing unauthorized use of IoT devices?”) and instrumented via quantitative metrics implemented in the UML metric layer. Every metric entry is tagged with:

- the associated ISO/IEC 27001 control ID(s) and short title(s),
- the corresponding NIST CSF 2.0 subcategory ID(s),
- the UML class that stores the metric (e.g., `AssetValue`, `ImpactLevel`, `HumanFactorMetric`),
- aggregation rules (per asset, per control, per time window).

The machine-readable GQM table is shipped as a `.csv` file in the artifact and is consumed by the validator. The same artifact bundle also exports a derived ISO $\leftrightarrow$ NIST informative-reference crosswalk from the official NIST informative references, enabling bidirectional consistency checks between the two frameworks. These validator checks demonstrate structural coverage and consistency while keeping the mapping baseline transparent and inspectable.

3.7. Standards Traceability and Reporting Exports

The standards-traceability layer provisions the GQM mappings and UML entities through dashboard-ready and reporting-ready exports rather than through a dedicated interactive dashboard implementation. For each ISO/IEC 27001 control or NIST CSF 2.0 subcategory, the exported summaries aggregate:

- current and historical metric values,
- residual-risk estimates and their decomposition by asset and event,
- three-year TCO contributions attributed to the relevant control portfolio.

These schema-linked outputs could allow downstream BI/dashboard layers or audit workflows to reconstruct decision rationales from controls to metrics and portfolio quantities. The shared repository documents the exported tables, plots, and schema fragments; it does not claim a full interactive dashboard or API product in the current artifact, and it does not report a user-, auditor-, or connector-level reuse study.

4. Discussion

This work proposes and operationalizes a standards-aligned representation, validation, and telemetry-derived evidence artifact with an architecturally implemented downstream risk layer. The shared artifact provides end-to-end traceability through a UML schema and a GQM matrix that fully covers ISO/IEC 27001 Annex A (93) and NIST CSF 2.0 (106). The reported public run is telemetry-only, boundary-safe, and explicit about provenance for CVSS, HF, and asset-value terms; in this strict profile, the non-telemetry enrichment factors remain proxies, neutral priors, or inactive overlays rather than fully validated empirical signals.

Practical implications. (i) *Governance:* Machine-readable mappings, coverage validation, and reporting-facing exports provide a candidate path from standards entries to measurable evidence, aligning with audit-oriented metric programs such as NIST SP 800-55 Rev. 2. In the strict public-data profile, however, this claim stops at export-layer provisioning; no auditor walkthrough, user study, or tool-integration deployment is evaluated. (ii) *Budgeting:* The GL bound, enforced at portfolio level, surfaces an explicit

frontier of cost–risk trade-offs under transparent control-catalog assumptions; in the strict public-data profile, NSGA-II returns a 61-point feasible frontier, Greedy returns a 14-point prefix frontier, and Exact-ILP returns a 16-point log-space frontier. The released artifact-default selector chooses a matched-budget trade-off with 4.5% lower residual risk and 5.0% higher three-year control TCO relative to the Greedy comparator. The accompanying weight-sensitivity check shows that this single-point recommendation is locally but not universally stable, so organizations should substitute elicited weights if available. (iii) *Operations*: The telemetry-only evidence path yields strong calibrated detection performance on the surrogate-heavy strict public profile, although the baseline suite shows that LightGBM slightly exceeds the artifact-default scorer on raw classification metrics. Those telemetry metrics should be interpreted as artifact-level operational benchmarks under source-file cohorts, synthesized ordering, and missing device-level attribution, not as strong deployment-level external-validity evidence. (iv) *Culture*: Explicit HF integration remains available in the artifact design, but the reported public run does not validate HF effects because no observed overlay is available.

Comparison to established frameworks.. OCTAVE FORTE, COSO ERM, and COBIT 2019 prioritize process governance and risk appetite; FAIR expresses risk in currency via frequency $\times$ magnitude. The proposed formulation complements these by contributing a machine-readable representation and standards-traceability layer that can host such factors in a reproducible artifact. In the strict public-data profile, however, the study does not claim a fully currency-calibrated or fully observed AV $\times$ EP $\times$ IL $\times$ HF deployment; those richer factors remain deployment-facing extensions for future validation.

Limitations.. (i) *Scope of empirical validation*—The strict public run validates the representation, mapping, and telemetry-derived evidence path, but it does not fully validate all downstream AV/CVSS/HF enrichment factors. In particular, because all reported public rows carry the same global neutral CVSS prior, Eq. (2)’s exploitability term is constant in this profile; the fitted β therefore acts only as a constant offset and does not validate a row-varying CVSS-driven exploitability effect. (ii) *Structural validity of evidence-to-control mappings*—The validation performed in this study is structural. The scripts verify coverage, identifier consistency, schema integrity, metric linkage, and reproducible report generation. They do not establish that

each individual evidence-control relation is the only or best possible interpretation. Therefore, the proposed mappings should be interpreted as a transparent and inspectable baseline for standards-oriented risk reporting rather than as a compliance oracle. (iii) *Decision weights*—The single-point portfolio selector uses artifact-default weights rather than stakeholder-elicited governance utilities. The reported $\pm 20\%$ perturbation analysis is only a local robustness check: it shows moderate stability around the default setting, but it does not replace formal preference elicitation or multi-stakeholder decision analysis. (iv) *Governance-facing reuse*—The artifact provisions reporting-facing exports, but no auditor walkthrough, user study, BI/dashboard deployment, API integration, or continuous-improvement workflow evaluation is reported. The current evidence therefore stops at export-layer traceability rather than demonstrated operational reuse. (v) *Surrogate-heavy telemetry profile*—Even within the reported IoT setting, the telemetry-only evaluation remains surrogate-heavy: source files stand in for verified devices, timestamps are synthesized, and row-level device attribution is unavailable. The strong F_1 /AUROC values should therefore be read as boundary-safe public-artifact benchmarks rather than as strong deployment-level evidence. (vi) *Domain*—Empirical validation is performed on CIC IoT 2023 and public-data enrichment; external validity to non-IoT enterprise IT/OT remains to be established. (vii) *Resource-aware evaluation*—The reported profile ingests all 63 merged CSV members but caps each at 1,000 rows to remain reproducible on commodity hardware; a heavier `real_full` profile is provided but not reported here. (viii) *HF data*—The reported run contains no observed human-factor overlay (`HF:none`); therefore, HF ablation is intentionally flat and organizational HF effects remain unvalidated. (ix) *Victim/device attribution*—The public CIC IoT 2023 release includes an official attack-victim inventory, but its CSV rows are anonymized with respect to victim/device identity; therefore, the strict reported evaluation cannot apply asset-specific CVE attribution and instead falls back to a global neutral CVSS prior. (x) *Asset valuation*—Public data do not provide enterprise asset-register values, so AV is represented by a telemetry-derived proxy over source-file cohorts rather than by verified device business values. (xi) *Ordering semantics*—Because the merged public CSV members do not carry observed timestamps, the reported ordered hold-out is induced from file-member sequence after timestamp synthesis; it is boundary-safe but remains a surrogate for true wall-clock deployment chronology. (xii) *Scenario-analytic control coefficients*—Portfolio effective-

ness, DR/FPR deltas, and control-side cost terms come from the configurable control catalog and should be read as transparent planning assumptions rather than measured intervention effects. (xiii) *Optimization comparison*—The optimization baselines are now synchronized as frontier-producing comparators, but they still evaluate scenario-analytic catalog assumptions rather than measured intervention effects; auxiliary DR/FPR policy thresholds are documented but disabled in the reported frontier comparison to avoid configuration-induced infeasibility. (xiv) *Classifier superiority is not claimed*—The artifact-default scorer is competitive but not dominant within the telemetry-only baseline suite; LightGBM slightly outperforms it on raw classification metrics. The framework treats IDS outputs as interchangeable evidence signals. (xv) *Class imbalance in the test split*—The test split is attack-dominant ($\approx 97.4\%$ malicious windows), so F_1 and PR-AUC are not interpreted in isolation. The default 0.5 threshold yields FPR = 0.208 (≈ 208 false alarms per 1,000 benign windows); under the validation-selected fixed-FPR operating-point protocol the realized test FPR falls to 0.004–0.013 while preserving a detection rate of 0.982–0.987. Specificity, balanced accuracy, MCC, and false alarms per 1,000 benign flows are reported alongside F_1 /AUROC in `out/real/default_telemetry_scorer_summary.csv` and `out/real/confusion_matrix.csv`. These results indicate that the calibrated score is useful as a risk-evidence signal, but operational deployment requires explicit FPR-constrained thresholding.

Future directions.. (a) Currency calibration against FAIR for selected asset classes; (b) adversarial training (contrastive-distilled detectors) within the pipeline; (c) SBOM-derived exploitability priors; (d) multi-domain datasets (enterprise IT, OT) with distribution-shift analysis; (e) causal evaluation of HF interventions using stepped-wedge designs.

5. Conclusions

This study introduced a machine-readable, standards-traceable framework for cybersecurity risk evidence representation and reporting. The artifact combines a UML/XMI schema, structurally checked ISO/IEC 27001 and NIST CSF 2.0 mappings, executable validators, telemetry-derived evidence generation, and reporting/export outputs. On the strict public CIC IoT 2023 profile, the evaluation establishes representation-level coverage, traceability, consistency, and reproducible artifact generation. It also demonstrates how

telemetry-derived scores can be transformed into risk-facing evidence and budget-aware portfolio scenarios.

The reported public run should not be interpreted as a full empirical validation of the complete AV–EP–IL–HF risk formulation. In this profile, CVSS exploitability is a constant neutral prior, asset value is a telemetry-derived proxy, human-factor effects are inactive, device attribution is cohort-based, and control-effectiveness coefficients are scenario-analytic assumptions. Because LightGBM slightly outperforms the artifact-default scorer on raw classification metrics, the IDS component is interpreted as an interchangeable evidence generator rather than as the paper’s main contribution. Accordingly, the principal result is not deployment-level risk-engine validation, but a reproducible standards-traceability artifact that preserves provenance from telemetry-derived evidence to mapping, validation, portfolio, and reporting outputs. In the downstream optimization layer, the primary scientific result is frontier-level: NSGA-II produces a 61-point feasible trade-off set with HV=31,436.9, compared with a 14-point Greedy frontier (HV=30,810.2) and a 16-point Exact-ILP frontier (HV=28,970.3). These results establish structural coverage, traceability, representation-level consistency, export-layer provisioning, and reproducible trade-off exploration; they do not establish stakeholder-elicited optimal decision weights, auditor/user/tool-level governance reuse, strong deployment-level external validity for the telemetry metrics, or universal superiority of a single portfolio point. Future work should attach observed HF telemetry, obtain a curator-supplied per-asset manifest that allows the public flow rows to be linked back to victim devices and to row-varying CVE/CVSS exploitability signals, replace telemetry proxies with verified asset-register valuations, replace surrogate ordering with true row-level timestamps, empirically calibrate control-catalog coefficients, elicit governance-specific portfolio utilities, execute auditor- or user-facing reuse studies, test BI/API integrations, execute the unrestricted `real_full` profile, and broaden validation across non-IoT domains.

Appendix A. Supplementary Material and Artifact Details

Detailed information regarding machine-readable mapping artifacts, reproducibility scripts, monetary-loss calibration details, hyperparameter configurations, and extended optimization baselines is provided in the supplementary material and the public repository.

Abbreviations

AV (Asset Value), EP (Event Probability), IL (Impact Level), RRL (Risk-Reduction Level), GL (Gordon–Loeb), GQM (Goal–Question–Metric), UML (Unified Modeling Language), RMF (Risk Management Framework), CSF (Cybersecurity Framework), TCO (Total Cost of Ownership), CVSS (Common Vulnerability Scoring System), XMI (XML Metadata Interchange), XAI (Explainable AI), IDS (Intrusion Detection System), EDR (Endpoint Detection and Response), SIEM (Security Information and Event Management), SBOM (Software Bill of Materials), NSGA-II (Non-Dominated Sorting Genetic Algorithm II), AUROC (Area Under the ROC Curve), FPR (False Positive Rate), DR (Detection Rate), HF (Human Factor), EWMA (Exponentially Weighted Moving Average).

Author Contributions

Conceptualization, methodology, software, validation, formal analysis, investigation, resources, data curation, writing—original draft preparation, writing—review and editing, visualization, supervision, project administration: E.E.

Funding

This research received no external funding.

Institutional Review Board Statement

Not applicable. This study used public or non-identifiable cybersecurity telemetry, vulnerability records, and repository artifacts only, and did not involve human participants or human-subjects procedures.

Informed Consent Statement

Not applicable. The study did not involve human participants or the collection of personal data.

Data Availability Statement

No new proprietary raw dataset was created for this study. The executable source code, manuscript sources, standards mappings, UML/XMI assets, validator outputs, and generated result artifacts reported in the manuscript are available in the shared repository (GitHub repository). The strict public profile relies on third-party CICIOT2023 releases and locally provisioned NVD/CVSS feeds; these upstream raw inputs are cited in the manuscript but are not redistributed through this repository. The repository documentation in `README.md` and `ai_risk/RUN.md` explains which derived artifacts are shared directly and why certain upstream raw inputs must be obtained from their original providers.

Acknowledgments

Early feedback on the UML schema and GQM mappings is gratefully acknowledged.

Conflicts of Interest

No conflict of interest is declared.

Declaration of Generative AI and AI-Assisted Technologies in the Manuscript Preparation Process

OpenAI Codex/GPT-based tools were used during manuscript preparation to support code inspection, consistency checks, and language refinement. All generated suggestions were reviewed, edited, and validated before inclusion. Full responsibility for the final manuscript content remains with the listed human author.

References

- [1] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, A. A. Ghorbani, Ciciot2023: A real-time dataset and benchmark for large-scale attacks in iot environment, *Sensors* 23 (13) (2023). doi:10.3390/s23135941.
URL <https://www.mdpi.com/1424-8220/23/13/5941>

- [2] Canadian Institute for Cybersecurity, CIC IoT dataset 2023—a real-time dataset and benchmark for large-scale attacks in iot environment, accessed: 03 Aug 2025 (2023).
URL <https://www.unb.ca/cic/datasets/iotdataset-2023.html>
- [3] I. O. for Standardization (ISO), Iso 31000:2018 – risk management – guidelines, revision confirmed in 2023, current and valid version as of 2025 (2018).
URL <https://www.iso.org/standard/65694.html>
- [4] AS/NZS 4360:2004 – Risk Management, https://infostore.saiglobal.com/en-au/standards/as-nzs-4360-2004-116097_saig_as_as_242206/ (2004).
- [5] International Organization for Standardization, ISO/IEC 27005:2022 Information Security, Cybersecurity and Privacy Protection – Information Security Risk Management, <https://www.iso.org/standard/75652.html>, accessed: 31 July 2025 (2022).
- [6] National Institute of Standards and Technology, Guide for conducting risk assessments, Tech. Rep. NIST SP 800-30 Rev. 1, NIST, official guidance used within NIST RMF; revision status confirmed April 2021, no Rev 2 issued as of August 2025 (September 2012).
URL <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>
- [7] Software Engineering Institute, Octave forte: Establish a more adaptable and robust enterprise risk management program, Tech. rep., Carnegie Mellon University, Software Engineering Institute, fact sheet describing the OCTAVE FORTE process model for ERM integration based on NIST RMF principles (June 2020).
URL <https://insights.sei.cmu.edu/library/octave-related-assets/>
- [8] R. H. J. Courtney, Courtney’s quantitative security risk assessment methodology, Tech. rep., National Bureau of Standards / National Computer Security Center, early risk analysis method based on threat frequency and financial impact estimates (1985).
URL <https://csrc.nist.gov/nist-cyber-history/risk-management/chapter>

- [9] L. A. Gordon, M. P. Loeb, The economics of information security investment, *ACM Transactions on Information and System Security* 5 (4) (2002) 438–457.
- [10] P. Radanliev, D. D. Roure, K. Page, J. R. C. Nurse, R. M. Montalvo, O. Santos, L. Maddox, P. Burnap, Cyber risk at the edge: current and future trends on cyber risk analytics and artificial intelligence in the industrial internet of things and industry 4.0 supply chains, *Cybersecurity* 3 (1) (2020) 13. doi:10.1186/s42400-020-00052-8.
URL <https://cybersecurity.springeropen.com/articles/10.1186/s42400-020-00052-8>
- [11] The Open Group, FAIR: Factor Analysis of Information Risk (2022).
- [12] F. R. Parente, E. B. Rodrigues, C. L. C. Mattos, FRAPE: A framework for risk assessment, prioritization and explainability of vulnerabilities in cybersecurity, *Journal of Information Security and Applications* 89 (2025) 103971. doi:10.1016/j.jisa.2025.103971.
URL <https://doi.org/10.1016/j.jisa.2025.103971>
- [13] M. A. Khalil, C. Gehrmann, T. Vogel, CyberROAD: A cybersecurity risk assessment ontology for automotive domain aligned with ISO/SAE 21434:2021, *Journal of Information Security and Applications* 90 (2025) 104015. doi:10.1016/j.jisa.2025.104015.
URL <https://doi.org/10.1016/j.jisa.2025.104015>
- [14] C. Depren, M. Topallar, E. Anarim, M. K. Ciliz, An intelligent intrusion detection system (ids) for anomaly and misuse detection in computer networks, *Expert Systems with Applications* 29 (4) (2005) 713–722. doi:10.1016/j.eswa.2005.05.002.
- [15] C.-F. Tsai, Y.-F. Hsu, C.-Y. Lin, W.-Y. Lin, Intrusion detection by machine learning: A review, *Expert Systems with Applications* 36 (10) (2009) 11994–12000. doi:10.1016/j.eswa.2009.05.029.
- [16] G. Apruzzese, P. Laskov, E. Montes de Oca, W. Mallouli, L. Brdalo Rapa, A. V. Grammatopoulos, F. Di Franco, The role of machine learning in cybersecurity, *Digital Threats* 4 (1) (mar 2023). doi:10.1145/3545574.
URL <https://doi.org/10.1145/3545574>

- [17] N. Mejri, L. Lopez-Fuentes, K. Roy, P. Chernakov, E. Ghorbel, D. Aouada, Unsupervised anomaly detection in time-series: An extensive evaluation and analysis of state-of-the-art methods, *Expert Systems with Applications* Article number 124922 (2024). doi:10.1016/j.eswa.2024.124922.
- [18] M. Wadinger, M. Kvasnica, Adaptable and interpretable framework for anomaly detection in scada-based industrial systems, *Expert Systems with Applications* Article number 123200 (2024). doi:10.1016/j.eswa.2024.123200.
- [19] S. Li, Y. Yao, A two-stage lightweight approach for intrusion detection in internet of things, *Expert Systems with Applications* Article number 124965 (2024). doi:10.1016/j.eswa.2024.124965.
- [20] Y. Yi, J. Wu, W. Xu, Incremental svm based on reserved set for network intrusion detection, *Expert Systems with Applications* 38 (6) (2011) 7698–7707. doi:10.1016/j.eswa.2010.12.141.
- [21] H. Rabiei, K. Khalili-Damghani, Introducing a novel multi-objective optimization model for volunteer assignment in the post-disaster phase: Combining fuzzy inference systems with nsga-ii and nrga, *Expert Systems with Applications* 226 (2023) 120142. doi:10.1016/j.eswa.2023.120142.
- [22] V. R. Basili, A. Trendowicz, M. Kowalczyk, J. Heidrich, C. Seaman, J. Münch, D. Rombach, *Aligning Organizations Through Measurement: The GQM+Strategies Approach*, The Fraunhofer IESE Series on Software and Systems Engineering, Springer, Cham, 2014. doi:10.1007/978-3-319-05047-8.
- [23] K. Deb, A. Pratap, S. Agarwal, T. Meyarivan, A fast and elitist multiobjective genetic algorithm: NSGA-II, *IEEE Transactions on Evolutionary Computation* 6 (2) (2002) 182–197.
- [24] National Vulnerability Database, NVD JSON 1.1 Data Feeds, accessed: 31 Jul 2025 (2025).
URL <https://nvd.nist.gov/vuln/data-feeds>
- [25] S. Hochreiter, J. Schmidhuber, Long short-term memory, *Neural Computation* 9 (8) (1997) 1735–1780.

- [26] D. P. Kingma, J. Ba, Adam: A method for stochastic optimization, Proceedings of the 3rd International Conference on Learning Representations (ICLR)ArXiv:1412.6980 (2015).
- [27] T. Chen, C. Guestrin, Xgboost: A scalable tree boosting system, in: Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, 2016, pp. 785–794. doi:10.1145/2939672.2939785.
- [28] F. Pedregosa, G. Varoquaux, A. Gramfort, V. Michel, B. Thirion, O. Grisel, M. Blondel, P. Prettenhofer, R. Weiss, V. Dubourg, J. Vanderplas, A. Passos, D. Cournapeau, M. Brucher, M. Perrot, E. Duchesnay, Scikit-learn: Machine learning in python, J. Mach. Learn. Res. 12 (null) (2011) 2825–2830.
- [29] A. Niculescu-Mizil, R. Caruana, Predicting good probabilities with supervised learning, Proceedings of the 22nd International Conference on Machine Learning (2005) 625–632doi:10.1145/1102351.1102430.